

AI Agents in CI/CD:

The lecture studies delegated authority: models propose actions, while the surrounding system decides what may happen.

- Open with your name and role, then frame the problem as delegated authority.
- A model proposes; the workflow grants authority and checks evidence.
- Name the arc: foundations, security boundaries, robustness, measurement, and research questions.
- Ask students to separate proved properties, measured observations, and design recommendations.

Keep in mind

Operational limits bound attempts; useful completion and effect safety require separate evidence.

Next

Here is the route from foundations to the evidence needed to operate these systems.

Companion article

[Start with the agent loop](#)

Lecture Outline

Each section adds one obligation needed before a probabilistic worker can safely participate in CI/CD.

- Foundations identify the principal, deputy, delegated objective, and authority.
- Security asks what can be enforced when content and model output remain untrusted.
- Robustness examines retries, feedback, state, and ambiguous external effects.
- Measurement asks whether accepted work improves outcomes after review, failure, and downstream cost.

Keep in mind

Keep three questions active: what is constrained, which assumptions support it, and what evidence could falsify the claim?

Next

Begin with a trace of observation, proposed action, tool result, and repetition.

Companion article

[Specify the system before claiming a guarantee](#)

Agent Architecture: From Theory to Tool-Use LLMs

Assurance starts by separating what the model proposes from what the environment actually executes.

- Represent a run as observations, requested actions, tool results, and updated state.
- Use the Universal Turing Machine comparison only as an analogy for unrestricted general computation.
- A finite attempt budget proves at most that the counted attempts cannot exceed the bound.
- Add wall-clock cancellation and explicit terminal states: accepted, failed, exhausted, or handed off.

Keep in mind

Turing's result limits a general decider for arbitrary programs; it does not forbid checking a bounded workflow or stopping a particular run.

Next

Once the model can request effects, ask whose authority it exercises.

Companion article

[Specify the system before claiming a guarantee](#)

The “Principal-Agent” Problem in AI Automation

Delegation quality depends on both the task class and the workflow that monitors and limits it.

- Name the organization as principal and the tool-using model as delegated worker.
- Incomplete observability raises review cost because the final diff hides much intermediate reasoning.
- Estimate success probability, verification effort, consequence, and reversibility by task class.
- Treat prompts, schemas, gates, and telemetry as different behavior-shaping or monitoring mechanisms.

Keep in mind

The economic language is an analogy: an LLM has no contractual incentives or personal exposure to downstream costs.

Next

The confused deputy gives a more precise account of authority misuse.

Companion article

[Treat tool use as delegated authority](#)

The Confused Deputy Revisited

Hardy (1988): a caller used the compiler's extra permissions to overwrite a billing file they could not write themselves.

- Setup: the compiler recorded usage statistics in (SYSX)STAT, so it had write access across SYSX.
- Redirection: the caller named (SYSX)BILL as debugging output. The compiler overwrote billing data using its own authority.
- Confusion: the caller chose the destination; the compiler supplied unrelated privileges. It mixed two sources of authority.
- Capability fix: use a dedicated STAT capability and a caller-provided output capability, each naming its authorized file.

Keep in mind

AI parallel: untrusted issue text chooses a target while the agent's broad credential supplies authority.

Next

Prompt injection is one route by which untrusted content can misdirect the deputy.

Companion article

[Treat tool use as delegated authority](#)

Injection Attack Taxonomy: Why Prompt Injection is Different

Prompt injection is an integrity problem at the language layer and an authority problem when interpreted text can cause effects.

- SQL parameters, context-aware web encoding, and shell avoidance each protect a defined syntactic boundary.
- Current agents often process policy, user intent, retrieved text, and tool output through one language mechanism.
- AgentDojo version 3 spans 97 user tasks and 629 eligible task-goal pairs, measuring utility with attack success.
- CaMeL evaluates 949 expanded attacks using separated planning, quarantined processing, capabilities, and data-flow policy.

Keep in mind

Benchmark resistance is distribution-specific; effect guarantees remain conditional on correct policy, annotations, mediation, and trusted components.

Next

Make those conditions visible by drawing identity, provenance, authority, and lifecycle boundaries.

Companion article

[State the threat model before reporting a rate](#)

Trust Boundary Analysis

Identity, content provenance, authority, and evidence lifetime answer different trust questions and must remain separate.

- A verified maintainer can paste hostile external text; identity does not sanitize content.
- Treat ticket bodies, repository files, logs, and model output as evidence with provenance.
- Grant only the effects required for the named repository, branch, task, and time window.
- Recheck eligibility and bind approval to the exact candidate revision before execution.

Keep in mind

Email-domain or changelog checks are meaningful only when the tracker supplies authenticated canonical identity and controlled audit semantics.

Next

Place explicit gates before execution and again before an artifact is accepted.

Companion article

[Treat tool use as delegated authority](#)

Case Study: Defense in Depth in Production

A gate should expose a versioned predicate, verdict, evidence record, and accountable owner at a named boundary.

- Pre-gates control admission and quarantine content before the model receives a task.
- Post-gates bind sensitive-path, secret, identity, and ticket checks to the candidate artifact.
- Several veto gates compose as conjunction for acceptance, without implying independent errors or complete coverage.
- Detectors lower risk for configured patterns; quarantine and review limit consequences after uncertain verdicts.

Keep in mind

Several gates can share a blind spot. A secret scanner is a detector, not proof of absence.

Next

Gates inspect named predicates; runtime containment limits which resources the worker can reach.

Companion article

[Build several enforcement boundaries](#)

Containment Primitives: Kernel-Level Enforcement

Containment is a composition of controls, each mediating a specific operation under deployment assumptions.

- Landlock restricts ambient filesystem rights, with behavior dependent on kernel support, ABI, and handled operations.
- Seccomp filters system calls and selected arguments, reducing kernel surface within a larger isolation design.
- Network namespaces force traffic through a path where destination and application policy can be applied.
- Test complete mediation, tamper resistance, alternate helpers, and failure behavior for the deployed composition.

Keep in mind

Kernel placement alone proves neither complete mediation nor overall sandbox security; allowed channels and configuration remain part of authority.

Next

OpenShell shows one concrete composition and the limits of turning product behavior into a security claim.

Companion article

[Build several enforcement boundaries](#)

Case Study: Sandboxing in Production

OpenShell combines job isolation, filesystem controls, network policy, and credential routing, but each property is version-specific.

- Public Agentic CI documentation supports an embedded gateway, Landlock controls, and endpoint policy.
- Current OpenShell documentation describes network namespaces, a policy proxy, seccomp, and privilege dropping.
- Credential handling differs by class: routed inference can retain provider keys at the host-side gateway.
- A denied CONNECT currently returns a structured 403, so do not narrate every denial as a silent drop.

Keep in mind

Allowed destinations still permit misuse. Neither a silent drop nor a proxy denial rules out side channels.

Next

Containment can deny an operation, but it cannot decide every semantic property of generated code.

Companion article

[Build several enforcement boundaries](#)

The Oracle Problem: Limits of Output Verification

Verification claims become useful only after defining the property, observation surface, enforcement power, and assumptions.

- Rice concerns nontrivial extensional properties of arbitrary programs in a Turing-complete model.
- Syntactic checks, types, bounded executions, finite models, and restricted contracts can remain decidable.
- Safety violations have finite bad prefixes that a sufficiently powerful monitor may suppress before execution.
- Liveness, such as eventually producing an acceptable patch, cannot generally be forced by stopping bad actions.

Keep in mind

A bounded model check proves only the modeled property under a justified bound or completeness argument; real-system conformance remains separate.

Next

Retry behavior tests these boundaries because the same logical operation may be attempted again.

Companion article

[Give acceptance authority to evidence](#)

Non-Determinism in Agentic Systems

Safe retry requires knowledge about the external effect, not confidence that a second sample will be better.

- CI already varies through clocks, networks, concurrency, mutable dependencies, and worker environments.
- Agentic CI adds variation in diagnosis and patch selection; temperature zero is not a universal reproducibility guarantee.
- Separate repeatable predicates, idempotent logical operations, and retries known safe after partial failure.
- Use stable operation keys and bind evidence to source, candidate, tool, and policy versions.

Keep in mind

A JSON schema validates shape, not truth, authorization, current state, or whether an external effect already occurred.

Next

When retries consume their own results, the workflow becomes a feedback system.

Companion article

[Recover effects using evidence, not the model's recollection](#)

Convergence and Divergence in Feedback Loops

Terminality, bounded attempts, convergence, and semantic improvement are four different properties.

- A fixed point requires an explicit transition function whose next state equals the current state.
- Passing tests and approval define acceptance, but rerunning a stochastic agent may still change the patch.
- A decreasing retry counter proves bounded attempts, not decreasing semantic error or useful completion.
- Persist accepted, rejected, failed, exhausted, needs-human, and unknown states outside model prose.

Keep in mind

Runtime shielding is correct only relative to its temporal specification, environment abstraction, available safe action, and mediated actuator set.

Next

A self-healing cycle shows why one local exclusion rule is useful but does not prove global acyclicity.

Companion article

[Prove a bound on attempts, then examine what it leaves open](#)

Case Study: Cycle Detection in Self-Healing CI

Cycle prevention requires an invariant over every trigger edge, not confidence in one label name.

- An analyzer can create work selected by a fixer, whose failure creates new analyzer input.
- Applying an exclusion label at creation removes one selection edge under the current admission rule.
- Protect origin lineage, restrict who can change it, and recheck the predicate when the action commits.
- A DAG proof needs the complete graph and a rank that strictly increases along every transition.

Keep in mind

One exclusion rule removes one path; every alternate trigger and lineage reset must respect the invariant.

Next

Instructions can influence a proposed edge, while policy must remove disallowed edges from execution.

Companion article

[Turn the agent loop into a bounded workflow](#)

Action Space Reduction via Skills

Skills structure model behavior, while independent runtime controls determine the executable action and effect space.

- A skill names procedure, inputs, output fields, stopping rules, and expected evidence.
- It can concentrate model proposals without removing a tool call that the runtime still permits.
- Separate possible proposals, exposed tools, state-dependent policy, and provider effects reachable through all paths.
- Validate referenced objects, revisions, evidence, and policy before mapping a structured verdict to authority.

Keep in mind

The type-system analogy applies only when declarations are independently checked and invalid transitions are refused.

Next

The same distinction between apparent structure and accepted effect determines what productivity metrics mean.

Companion article

[Turn the agent loop into a bounded workflow](#)

Measuring AI Agent Productivity

Evaluate the complete assisted workflow against a defined counterfactual, including failure and human effort.

- Register eligible tasks before assignment; retain accepted, revised, rejected, abandoned, blocked, and unresolved outcomes.
- Randomize when feasible; matching alone leaves task choice, familiarity, maturity, and urgency as possible confounders.
- Sum model, CI, diagnosis, review, rework, and downstream costs across every attempt exactly once.
- Divide cohort cost by accepted outcomes, while reporting human hours and the terminal-outcome distribution separately.

Keep in mind

METR's 2025 result and randomized 2026 follow-up concern narrow study populations; selection and measurement changes limit transfer to current CI workflows.

Next

Review time is both a cost and a behavior that automation can change.

Companion article

[Estimate productivity with an explicit counterfactual](#)

Automation Bias and Over-Reliance

Human review quality is an empirical outcome shaped by information order, workload, verification cost, and trust in automation.

- Separate omission errors after missing warnings from commission errors that follow incorrect advice.
- Give reviewers the diff, bound revisions, commands, policy evidence, and unresolved gaps before a verdict.
- Test whether showing the model verdict before independent assessment changes detection or confidence calibration.
- Evaluate alert suppression through precision, recall, review time, and consequential defect detection.

Keep in mind

Existing automation-bias literature motivates a CI hypothesis; it does not prove that better agents necessarily cause worse code review.

Next

This turns human involvement into an authority and information-flow design rather than a slogan.

Companion article

[Give acceptance authority to evidence](#)

Human-in-the-Loop as Supervisory Control

Supervisory control is useful when consequence and semantic uncertainty exceed what automated evidence can justify.

- Map repository and pipeline to plant, checks to sensors, agent to controller, and tool APIs to actuators.
- A supervisor may switch from the advanced controller to denial, staging, rollback preparation, or handoff.
- Approval becomes a hard gate only when bound to the exact head and unavoidable by the agent.
- Ask whether state, sensors, transition model, and safe fallback are faithful enough for the claimed envelope.

Keep in mind

Stochasticity does not prove that no Lyapunov function exists, and theory does not require a human for every low-consequence action.

Next

Production observations should now be read as evidence under exposure, not as proof of the controls.

Companion article

[Supervisory control requires a specified model](#)

Production Evidence at Scale

Operational counts establish activity and exposure, while causal benefit and safety require denominators, definitions, and detection coverage.

- 100+ MRs per week: activity volume; acceptance, rework, and value need their own evidence.
- 7 workflows, 15+ projects, 5 engineers: scope and exposure in the displayed snapshot.
- Zero observed incidents: ask about the time window, incident definition, and detection coverage.
- An observed outcome does not identify which control caused it or establish future risk.

Keep in mind

Treat these as the slide's dated snapshot, not a causal estimate or a current universal result.

Next

The distance between those observations and desired guarantees defines the research agenda.

Companion article

[Quantify uncertainty without manufacturing precision](#)

Open Research Problems

Turn broad safety topics into experiments with explicit systems, adversaries, properties, and failure criteria.

- Model typed effects and verify candidate-bound approval or at-most-one-effect properties under injected crashes.
- Compare injection defenses on eligible pairs, separating useful completion, prohibited effects, and text-only corruption.
- Audit model-proposed capability manifests against deterministic policy for excess grants and blocked legitimate work.
- Test ambiguous timeouts where no commit and committed-with-lost-response yield the same local observation.

Keep in mind

The timeout argument is a synthesis under a stated observation model, not a universal impossibility theorem; stronger provider information can resolve ambiguity.

Next

Close by converting each research lesson into one implementable obligation.

Companion article

[Research problems hidden inside the workflow](#)

Key Takeaways

Reliable agentic CI comes from bounded authority, explicit state, independently checked evidence, and decision-relevant measurement.

- Prevent confused-deputy failures by connecting every request to narrow, current authority.
- Combine measured resistance to hostile text with enforced limits on data and tool effects.
- Treat retries statistically, but retain deterministic checks for the exact predicates they encode.
- Expand authority only after accepted value exceeds review, rework, failure, and downstream cost.

Keep in mind

Every assurance statement must name its property, observation surface, enforcement point, trusted components, and remaining exclusions.

Next

Use the remaining time to test those assumptions against the audience's questions.

Companion article

[Research problems hidden inside the workflow](#)

Questions?

Use questions to clarify which guarantee is behavioral, architectural, empirical, or still an open research hypothesis.

- Second LLM? Another measured detector; shared models and data can create correlated blind spots.
- Read-only useful? Yes for analysis and review; grant writes only when the workflow requires them.
- Timeout after PR creation? Query stable operation state, then retry only with idempotency or known non-application.
- Strongest claim? A named broker blocks a defined finite bad prefix under stated mediation and conformance assumptions.

Keep in mind

Human review adds context and accountability but is not an oracle; scope retained authority by consequence, reversibility, and measured residual risk.

Next

Return to the central question: what exact effect can this system justify under its stated evidence?

Companion article

[Research problems hidden inside the workflow](#)